



Analytic Rules Gap Analysis

AB Bank Liberia

Contents

1. EXECUTIVE SUMMARY	2
2. RECOMMENDATIONS	3
2.1. FortiGate Failed SSH Connection	3
<i>Description: Detects failed SSH connection attempts observed on FortiGate devices where authentication to TCP port 22 is unsuccessful. Useful for identifying repeated login failures, brute-force or password-spraying attempts, unauthorized administrative access, compromised credentials, or misconfigured automated services attempting to connect using invalid credentials.</i>	
Severity: Medium	3
Rule Frequency: 15 minutes Rule Period: 15 minutes	3
MITRE ATT&CK Mapping:	3
- TA0006 Credential Access	3
o T1110 Brute Force	3
- TA0001 Initial Access	3
o T1078 Valid Accounts	3
Entity Mapping:	3
Host: DestinationHostName	3
Account: SourceUserName	3
IP: SourceIP	3
Event grouping:	3
- Group all events into a single alert	3
Rule Query:	3
2.2. Rationalization of Account Lockout Analytical Rules	4

1. Executive Summary

This report presents the results of a Microsoft Sentinel analytic rule gap and rationalization review for the AB Bank Liberia Sentinel workspace. The review focused on improving detection coverage for FortiGate failed SSH and failed administrative authentication activity, while also reducing duplicate account-lockout incidents caused by overlapping Event ID 4740 analytics rules.

The analysis is based on FortiGate Syslog telemetry and Windows Security Event/account-lockout detections currently used by Microsoft Sentinel. These data sources support monitoring of firewall administrative access attempts and account lockout activity across privileged, critical, and regular user accounts.

Identified Issue:

Two primary issues were identified. First, failed SSH connection activity on FortiGate devices requires a purpose-built Sentinel analytic rule to ensure unsuccessful administrative access attempts are consistently detected. Second, overlapping account-lockout rules currently monitor the same Event ID 4740 activity, which can create duplicate Sentinel alerts and inflated incident counts.

Impact Assessment:

No confirmed compromise was identified from this review. However, the current rule posture may either miss important FortiGate SSH failed-login activity or generate duplicate account-lockout incidents. This reduces alert fidelity, increases SOC triage effort, and may affect the accuracy of monthly Sentinel reporting.

Root Cause:

The root cause is inconsistent Sentinel analytic rule scoping. FortiGate failed SSH activity requires a dedicated rule using parsed Syslog fields, while account-lockout detection requires rationalization so generic and broad rules do not duplicate the dedicated Admin User and Regular User lockout rules.

Recommendation:

Implement the FortiGate Failed SSH Connection analytic rule, disable or remove the duplicate AD Account Lockout rules, and remove Event ID 4740 from Critical User Events. Account lockout monitoring should remain within the dedicated Admin Users and Regular Users rules.

2. Recommendations

This section provides recommended Microsoft Sentinel analytic rule configurations for the AB Bank Liberia Sentinel workspace to enhance visibility of analytical rules and remove redundant analytic rule.

The review identified some inconsistently scoped or broadly defined analytic rules that may contribute to alert gaps or duplication. To improve detection coverage, reduce redundancy, and standardize monitoring, we recommend consolidating certain existing rules into more clearly defined and purpose-built configurations as outlined below.

2.1. FortiGate Failed SSH Connection

Description: Detects failed SSH connection attempts observed on FortiGate devices where authentication to TCP port 22 is unsuccessful. Useful for identifying repeated login failures, brute-force or password-spraying attempts, unauthorized administrative access, compromised credentials, or misconfigured automated services attempting to connect using invalid credentials.

Severity: Medium

Rule Frequency: 15 minutes **Rule Period:** 15 minutes

MITRE ATT&CK Mapping:

- TA0006 Credential Access
 - o T1110 Brute Force
- TA0001 Initial Access
 - o T1078 Valid Accounts

Entity Mapping:

Host: DestinationHostName

Account: SourceUserName

IP: SourceIP

Event grouping:

- Group all events into a single alert

Rule Query:

```
Syslog
| where HostIP in ("172.18.1.1", "172.19.254.1")
| extend
    LogDesc = extract(@"logdesc="([^"]+)"", 1, SyslogMessage),
    Method = extract(@"method="([^"]+)"", 1, SyslogMessage),
    User = extract(@"user="([^"]+)"", 1, SyslogMessage),
    SrcIp = extract(@"srcip=([\s]+)", 1, SyslogMessage),
    DstIp = extract(@"dstip=([\s]+)", 1, SyslogMessage),
    Action = extract(@"action="([^"]+)"", 1, SyslogMessage),
    Status = extract(@"status="([^"]+)"", 1, SyslogMessage),
```

```

        Reason = extract(@"reason="([^"]+)"", 1, SyslogMessage),
        UI = extract(@"ui="([^"]+)"", 1, SyslogMessage)
    | where
        Method =~ "ssh"
        or UI startswith "ssh("
    | where
        Status =~ "failed"
        or LogDesc =~ "Admin login failed"
        or Reason in~ (
            "passwd_invalid",
            "ssh_key_invalid"
        )
    | project
        TimeGenerated,
        HostIP,
        SrcIp,
        DstIp,
        User,
        Method,
        Status,
        Reason,
        LogDesc,
        UI
    | order by TimeGenerated desc

```

2.2. Rationalization of Account Lockout Analytical Rules

A review of the existing Microsoft Sentinel analytic rules identified overlapping detection logic for Windows Security Event ID 4740, which represents an account lockout event.

The current rule configuration includes multiple analytics capable of detecting the same underlying lockout activity. This overlap can cause a single account lockout event to generate multiple Sentinel alerts or incidents, resulting in duplicate investigations, inflated incident volumes, and unnecessary SOC workload.

The affected rule set includes:

- **AD Account Lockout**
- **AD Account Lockout (duplicate rule)**
- **Critical User Events**

- **Account Lockout: Admin Users**
- **Account Lockout: Regular Users**

The recommended approach is to consolidate account-lockout monitoring into the two purpose-built rules already designed for this use case:

- **Account Lockout: Admin Users**
- **Account Lockout: Regular Users**

This will allow account lockout activity to remain visible while ensuring that alerts are categorized by account criticality and investigated with the right level of priority.

Disable or Remove Both “AD Account Lockout” Analytics Rules

Two analytic rules named AD Account Lockout are currently configured in the environment. These rules should be considered redundant because the same Event ID 4740 activity is already covered by more targeted lockout rules.

Keeping the generic AD Account Lockout rules active alongside the dedicated Admin User and Regular User lockout rules may result in duplicate incidents for the same event. This reduces the quality of Sentinel reporting and increases analyst effort without adding meaningful detection value.

Recommendation:

It is recommended that both AD Account Lockout analytics rules be disabled or removed. Account lockout monitoring should remain active through the dedicated Account Lockout: Admin Users and Account Lockout: Regular Users rules. This will reduce duplicate alerts, improve incident accuracy, and help ensure monthly reporting reflects unique security events rather than repeated detections of the same activity.

Remove Event ID 4740 from the “Critical User Events” Analytics Rule

Event ID 4740 is also currently included in the broader Critical User Events analytic rule. This creates additional overlap because account lockout events involving critical users may trigger both the Critical User Events rule and one of the dedicated account-lockout rules.

The Critical User Events rule should remain focused on broader privileged or sensitive account activity, such as account modifications, privilege changes, suspicious administrative actions, or other high-value user events. Account lockouts should instead be handled by the dedicated lockout rules, where they can be categorized more accurately as either admin-user or regular-user lockout activity.

Recommendation:

It is recommended that Event ID 4740 be removed from the query logic of the Critical User Events analytic rule. Lockout detection should be retained only within the dedicated **Account Lockout: Admin Users** and **Account Lockout: Regular Users** rules.

This adjustment will preserve visibility into account lockouts while preventing the same lockout event from being counted under multiple incident categories.

Expected Outcome

Implementing this rationalization will:

- Reduce duplicate Sentinel incidents
- Improve alert fidelity and triage efficiency
- Provide clearer separation between admin-user and regular-user lockout events
- Improve monthly incident reporting accuracy
- Reduce unnecessary SOC investigation effort
- Allow Critical User Events to focus on higher-value privileged account activity

- Preserve lockout monitoring without weakening detection coverage

1. Other Tuning Recommendations

The following detection rules currently have duplicate active copies. We recommend disabling one duplicate copy for each rule:

2. Account Modification

3. Base64 Encoded Windows Process Command Lines

4. Lateral Movement via DCOM

Overall, this change will make account-lockout monitoring cleaner, more purposeful, and easier to report on. It does not remove lockout visibility; it simply ensures that each lockout event is detected by the most appropriate analytic rule.